

Metod för riskbedömning av kund

Version 3.0 – Celestial Risk Engine

Celestial AB

Penningtvättsansvarig

25 oktober 2025

Innehåll

1 Introduktion och metodval

1.1 Syfte

Detta dokument beskriver Celestial AB:s metod för riskbedömning av kunder enligt Penningtvättslagen (PTL 2017:630). Metoden används för att klassificera nya kunder i riskklasser och avgöra om Enhanced Due Diligence (EDD) krävs.

Version 3.0 ersätter tidigare Hot×Sårbarhet-modell och inför en enhetlig 0–100 poäng-baserad Celestial Risk Engine.

1.2 Regelverkskrav

- **PTL 3 kap 2 §:** Riskbaserade kundkännedomsåtgärder
- **PTL 3 kap 10 §:** Fördjupad kundkännedom vid förhöjd risk
- **FFFS 2009:1:** Finansinspektionens föreskrifter om åtgärder mot penningtvätt och finansiering av terrorism
- **EU-direktiv 2015/849 (4:e penningtvättsdirektivet):** Riskbaserat arbetssätt

1.3 Metodöversikt

Celestial Risk Engine kombinerar tre datakällor:

1. **Offentliga register** (30% vikt): Bolagsverket, SPAR, Roaring (PEP, sanktioner, näringsförbud)
2. **Korsvalidering** (30% vikt): Avvikelse mellan registerdata (VH-mismatch, adress-mismatch, F-skatt/moms)
3. **Bokföringsdata** (40% vikt): SIE-fil analys, bankkonto, nyckeltal

Steg 1 (Statisk KYC) beräknar en `staticKycScore` (0–100) baserat på punkt 1–2 ovan (bokföring = 0 initialt).

Senare steg lägger till bokföringskomponenten (40%) när SIE-fil och bankkonto analyseras.

2 SNI-kod och Hotfaktor

2.1 Hotfaktor (1–4) från branschkod

Varje företags SNI-kod (Svensk Näringsgrensindelning) mappas till en **Hotfaktor** enligt Finansinspektionens riskklassificering av branscher:

Hot	Branschtyp
1	Lågrisk: Konsulttjänster, IT, utbildning, design
2	Normal risk: Handel (ej kontanter), tillverkning, bygg
3	Förhöjd risk: Restaurang, taxi, frisör, bilhandel (kontantintensiv)
4	Hög risk: Spelverksamhet, valutaväxling, ädelmetaller, begagnathandel

Tabell 1: SNI-kod till Hotfaktor-mappning

Källa: Bolagsverket API returnerar SNI-kod automatiskt vid validering av organisationsnummer.

2.2 Hotfaktorns påverkan på riskscore

Hotfaktorn används för att lägga till en **hotbonus** direkt till den statistiska KYC-scoren:

$$\text{hotBonus} = (\text{sniHotFactor} - 1) \times 10 \quad (1)$$

$$\text{adjustedScore} = \text{publicData} + \text{crossValidation} + \text{bookkeeping} + \text{hotBonus} \quad (2)$$

Exempel:

- Hot 1 (lågrisk): $\text{hotBonus} = (1 - 1) \times 10 = 0$ poäng
- Hot 2 (normal): $\text{hotBonus} = (2 - 1) \times 10 = 10$ poäng
- Hot 3 (förhöjd): $\text{hotBonus} = (3 - 1) \times 10 = 20$ poäng
- Hot 4 (hög): $\text{hotBonus} = (4 - 1) \times 10 = 30$ poäng

Motivering: Kontantintensiva branscher (Hot 3–4) kräver extra granskning enligt PTL 3 kap 10 § 2 p. Den direkta additionen gör beräkningen transparent och lätt att följa i granskningssyfte.

3 Celestial Risk Engine – Beräkningsmodell

3.1 Komponent 1: Offentliga register (max 30 poäng)

Datakällor:

- Bolagsverket: Företagsålder, organisationsform, status
- SPAR: Folkbokföring VD/firmateknare
- Roaring: PEP-status, sanktionslistor, näringsförbud, verkliga huvudmän

Poängberäkning:

Faktor	Villkor	Poäng
Bolagsålder	< 1 år	+8
	1–3 år	+4
	> 3 år	0
PEP-status	Någon huvudman är PEP	+10
Sanktioner	Träff på sanktionslista	+30 (→ critical)
Näringsförbud	Aktiv näringsförbudad person	+30 (→ critical)
Utländsk VD	VD ej folkbokförd i Sverige	+5

Tabell 2: Offentliga register – poängtabell

Max-tak: 30 poäng (utom vid sanktioner/näringsförbud som ger automatisk **critical**-klassning).

3.2 Komponent 2: Korsvalidering (max 30 poäng)

Avvikelser mellan registerdata:

Max-tak: 30 poäng.

Motivering: Avvikelser mellan register indikerar potentiella strukturer för skatteundandragande eller penningtvätt (PTL 3 kap 10 § 1 p).

Avvikelse	Beskrivning	Poäng
VH-mismatch	Användare påstår sig vara VH men Roaring visar ej	+15
Adressmismatch	SPAR-adress $\neq$ Bolagsverket-adress	+8
Saknad F-skatt	Fakturerar men ej F-skattsedel	+10
Saknad momsreg.	Omsättning > 30 000 kr men ej momsregistrerad	+12
Dubblad VD	Samma person VD i > 5 bolag	+6

Tabell 3: Korsvalidering – poängtabell

3.3 Komponent 3: Bokföringsdata (max 40 poäng)

Analyseras i senare steg när SIE-fil och bankkonto laddas upp.

Indikatorer:

- Kassaandel > 40% av omsättning (+12 poäng)
- Negativ soliditet < -20% (+8 poäng)
- Extraordinära transaktioner > 500 000 kr utan verifikat (+15 poäng)
- Utländska transaktioner till högrisländer (FATF grå-/svartlista) (+10 poäng)
- Avvikelse bokföring vs. deklaration > 15% (+8 poäng)

Max-tak: 40 poäng.

I Steg 1 sätts denna komponent till 0, eftersom bokföring ännu ej analyserats.

4 Riskklassificering – Fyrgradig skala

4.1 Finansinspektionens standard

Celestial AB använder Finansinspektionens fyrgradig riskskala (FFFS 2009:1):

1. **Låg risk** (Low): Standardiserad kundkännedom
2. **Förhöjd risk** (Medium): Utökad kundkännedom
3. **Hög risk** (High): Enhanced Due Diligence (EDD) enligt PTL 3 kap 10 §
4. **Oacceptabel risk** (Critical): Avslag av uppdrag, anmälningssplikt Finanspolisen

4.2 Tröskelvärden

Beräkning:

$$\text{adjustedScore} = \text{publicData} + \text{crossValidation} + \text{bookkeeping} + \text{hotBonus} \quad (3)$$

$$\text{där hotBonus} = (\text{sniHotFactor} - 1) \times 10$$

4.3 Hårda triggers (automatisk Critical)

Oavsett score klassas kunden som **critical** vid:

- Träff på sanktionslista (Roaring Sanctions API)
- Aktivt näringsförbud (Roaring Business Prohibition API)
- Flera allvarliga avvikelser: VH-mismatch + saknad F-skatt + PEP

Riskklass	adjustedScore	Åtgärd
Low	0–40 poäng	Standardiserad KYC
Medium	41–70 poäng	Utökad KYC, extra dokumentation
High	71–90 poäng	EDD, godkännande av PTL-ansvarig
Critical	> 90 poäng eller hårda triggers	Avslag, eventuell anmälan

Tabell 4: Riskklassificering – tröskelvärden

4.4 Eskaleringstriggrar (höjer riskklass ett steg)

Om `adjustedScore` ligger på gränsen (t.ex. 38–42 eller 68–72) eskaleras riskklass vid:

- PEP-status + score > 35 → Low blir Medium
- VH-mismatch + score > 60 → Medium blir High
- Utländska partners (högrisländer) + score > 55 → Medium blir High

5 Implementering i Steg 1 API

5.1 Response-struktur

Endpoint: POST `/api/onboarding/{onboardingId}/riskfragor/steg1`

Response (förenklad):

```
{
  "success": true,
  "riskAssessment": {
    "staticKycScore": 45,
    "adjustedScore": 59,
    "sniHotFactor": 3,
    "riskLevel": "medium",
    "requiresEDD": false,
    "components": {
      "publicData": 12,
      "crossValidation": 18,
      "bookkeeping": 0
    },
  },
  "triggers": {
    "isPEP": false,
    "hasSanctions": false,
    "hasBusinessProhibition": false,
    "vhMismatch": false,
    "addressMismatch": true,
    "missingFTax": false
  }
},
"nextStep": "/riskfragor/steg2"
}
```

5.2 Beräkningsflöde

1. Hämta SNI-kod från Bolagsverket $\rightarrow$ `sniHotFactor` (1–4)
2. Beräkna `publicData` (0–30 poäng)
3. Beräkna `crossValidation` (0–30 poäng)
4. Sätt `bookkeeping` = 0 (fylls i senare)
5. `staticKycScore` = `publicData` + `crossValidation` + `bookkeeping`
6. `hotBonus` = (`sniHotFactor` - 1) $\times$ 10
7. `adjustedScore` = `staticKycScore` + `hotBonus`
8. Klassificera `riskLevel` enligt tröskeltabell (0-40 Low, 41-70 Medium, 71-90 High, >90 Critical)
9. Kontrollera hårda triggers $\rightarrow$ eventuellt tvinga `critical`
10. Kontrollera eskaleringstriggar $\rightarrow$ eventuellt höj riskklass

6 Exempel: Restaurangföretag

6.1 Scenariodata

- **Företag:** Celestial Restaurang AB
- **SNI-kod:** 56101 (Restaurangverksamhet) $\rightarrow$ Hot 3 (kontantintensiv)
- **Bolagsålder:** 2 år (registrerat 2023-01-15)
- **VD:** Bengt Bengtsson (personnr 197001011234)
- **Verkliga huvudmän:** Bengt 60%, Lisa Larsson 40%
- **PEP:** Nej
- **Sanktioner:** Nej
- **Avvikelser:** Adressmismatch (SPAR vs. Bolagsverket)

6.2 Beräkning

Steg 1: Offentliga register

- Bolagsålder 1–3 år: +4 poäng
- PEP: 0 poäng
- Sanktioner: 0 poäng
- Totalt: 4 poäng

Steg 2: Korsvalidering

- Adressmismatch: +8 poäng
- Övriga: 0 poäng
- Totalt: 8 poäng

Steg 3: Bokföringsdata

- Ännu ej analyserad: 0 poäng

`staticKycScore` = 4 + 8 + 0 = 12 poäng

Steg 4: Hot-bonus

- SNI 56101 = Restaurang $\rightarrow$ Hot 3 (kontantintensiv)
- `hotBonus` = (3 - 1) $\times$ 10 = 20 poäng

adjustedScore = $12 + 20 = 32$ poäng

Riskklass: Low (0–40 poäng)

requiresEDD: false

6.3 Kommentar

Trots att restaurangbranschen är kontantintensiv (Hot 3, +20 poäng) är företaget fortfarande i "Low"-klass eftersom:

- Inga allvarliga avvikelser (endast mindre adressmismatch)
- Inga PEP/sanktioner/näringsförbud
- Bokföring ej analyserad ännu (kan höja score senare)
- Total score 32 poäng ligger under Low-gränsen (40 poäng)

Om senare SIE-analys visar hög kassaandel ($> 40\%$) kan score stiga mot Medium-klass.

7 Uppdatering vid bokföringsanalys

När SIE-fil och bankkonto analyseras (senare i onboarding-flödet):

1. Beräkna **bookkeeping**-komponenten (0–40 poäng)
2. Uppdatera **staticKycScore** = **publicData** + **crossValidation** + **bookkeeping**
3. Räkna om **adjustedScore**
4. Omklassificera **riskLevel**
5. Om riskklass höjs: Notifiera PTL-ansvarig, kräv extra dokumentation

Exempel fortsättning (Restaurang):

SIE-analys visar:

- Kassaandel 48% av omsättning: +12 poäng
- Soliditet -5%: 0 poäng (gräns är $< -20\%$)
- Totalt bookkeeping: 12 poäng

Ny **staticKycScore** = $4 + 8 + 12 = 24$ poäng

Ny **adjustedScore** = $24 + 20 = 44$ poäng

Ny **riskklass:** Medium (41–70 poäng)

Kommentar: Med hög kassaandel eskaleras företaget från Low till Medium-klass. Extra dokumentation och fördjupad granskning av kontanthantering krävs nu enligt PTL.

8 Sammanfattning och riktlinjer

8.1 Nyckelprinciper

1. **Riskbaserat:** Högre risk = mer granskning, inte automatiskt avslag
2. **Dynamiskt:** Score uppdateras när mer data tillkommer
3. **Transparent:** Kunden ser sin riskklass och kan förklara avvikelser
4. **Regelefterlevnad:** Baserat på PTL, FFFS 2009:1 och FATF-rekommendationer

8.2 Ansvar

- **Systemet:** Automatisk beräkning av staticKycScore och riskLevel
- **PTL-ansvarig:** Godkänner High-klassade kunder, beslutar om EDD-åtgärder
- **VD:** Slutligt beslut vid Critical-klass (avslag eller anmälan)

8.3 Dokumentation

Alla riskbedömningar loggas i `event_log.csv` (CSV-first approach) med:

- Timestamp
- onboardingId
- staticKycScore, adjustedScore, riskLevel
- Triggers som aktiverades
- PTL-ansvarigs kommentar (vid High/Critical)

Godkänd av: [PTL-ansvarig namn]

Datum: 25 oktober 2025

Nästa revidering: Årligen eller vid regeländringar